
ISO/IEC 29100:2024

Plain-Language Privacy Framework Reference

Terminology, principles, and roles — mapped to the vocabulary you already use

What each term means, why the framework defines it that way, how it maps to the vocabulary you already use, and where the two quietly diverge.

Coverage

All eleven privacy principles.

The four actor roles and how they combine and shift.

The core terminology, including PII, sensitive PII, and privacy breach.

The framework components, including privacy safeguarding requirements.

Audience

Privacy practitioners fluent in GDPR or another regulatory vocabulary who need to read, write, or cite documents that use this one.

Before You Use This Document

This is a companion guide, not a copy of the standard.

ISO/IEC 29100:2024 is a publication of ISO and IEC. Nothing in this document reproduces its text. Every term here is described in original wording, using the official principle and term names as reference points only.

Unusually, you can obtain this one for free. ISO/IEC 29100 has been made available at no charge through the ISO and IEC freely available standards programmes. Almost nothing else in this guide series is. Since the whole value of a terminology standard is that people share the vocabulary, circulate the source document to your team rather than a summary — including rather than this guide. Verify current availability, as programme contents change.

Nothing is certified against this standard, and it imposes no obligations. It is a framework: it supplies definitions, eleven privacy principles, and the actor roles that other standards build on. ISO/IEC 27701 specifies a certifiable management system using this vocabulary; ISO/IEC 29134 supplies an impact assessment methodology; ISO/IEC 29151 supplies a control set. If a requirements document traces an obligation to 29100, it has cited the wrong source.

The 2024 edition is the second, a minor revision of the 2011 original consolidating Amendment 1:2018. Material written against the earlier edition largely remains sound.

What this guide does

It takes each principle, role, and term in ISO/IEC 29100:2024 and answers six questions about it, in the same order every time:

1. **What the term means.** The definition in ordinary language, with no assumed background.
2. **Why the framework defines it this way.** The reasoning behind the choice. Several of these definitions look eccentric until you see the problem they solve.
3. **Mapping to vocabulary you already use.** How the term relates to GDPR, and where relevant to ISO/IEC 27701 and other regimes. This is the section most readers will use most.
4. **Related terms and where they sit.** The adjacent concepts, so you can navigate between them rather than reading linearly.
5. **Using it precisely.** How to write with the term without creating ambiguity, particularly in documents that mix vocabularies.
6. **Where this goes wrong.** The specific misreading this term actually produces. Not a hypothetical — the mistake practitioners make.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning. Here it marks one thing: whether the term *diverges* from the regulatory vocabulary most practitioners think in.

Orange, marked CVB

Diverges from GDPR vocabulary or conceptual structure in a way that causes misreading. These are the entries where assuming you know what a term means will mislead you.

Blue

Maps closely enough onto familiar vocabulary to carry across safely.

Twenty-three of the twenty-nine entries are orange, which is the honest headline of this document. The two vocabularies partition the same territory differently: GDPR has six principles plus accountability where this framework has eleven, and the extra principles are not additions on top but redistributions of the same ground. Purpose limitation splits one way here and another way there. Collection limitation and privacy compliance have no GDPR counterpart at all.

This is why the risk in this document is not non-compliance. Nothing is certified against 29100 and it imposes no obligations, so there is no compliance to fail. The risk is silent mistranslation: a reader fluent in one vocabulary assuming the terms mean what they mean elsewhere, and being wrong in ways that never announce themselves.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The classification is a judgment, not something the standard states; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

How this guide is organized

The first chapter covers all eleven privacy principles. The three that follow cover the actor roles, the core terminology, and the framework components. Entries cross-reference each other by name, so the guide can be read in any order or used as a lookup.

Five divergences worth knowing before you start

Privacy policy does not mean the website document. In this vocabulary a policy is the organization's internal governing statement; the public document is a *notice*. This is the most frequent terminology error in the whole framework, and it propagates into requirements documents that then serve neither audience.

Sensitive PII is not GDPR special categories. Article 9 is a closed list of nine categories. Sensitive PII is a property arising from nature, context, or processing, so information can be sensitive here and outside Article 9 entirely. Location data is the standard example.

Privacy breach is wider than personal data breach. GDPR requires a breach of security. This framework also covers processing that violates safeguarding requirements without any security failure — PII used beyond its purpose, retained past its period, disclosed without basis. The two definitions do not partition incidents the same way, which bears directly on notification decisions.

Two principles have no GDPR counterpart. Collection limitation is folded into minimisation there; privacy compliance is folded into accountability. When mapping across, these are the ones that silently disappear, taking the collection question and the verification dimension with them.

The purpose principles split the opposite way. GDPR purpose limitation covers both specification and the constraint on further processing. This framework puts specification in one principle and downstream constraints in another. Any one-to-one mapping loses half the meaning in each direction.

Three concepts you need before anything else

PII and linkability

Personally identifiable information is information that can identify a person or that is, *or might be*, linked to them. The might-be formulation makes the boundary relative: whether data is PII depends on what else exists and who holds it. The same dataset can be PII in one environment and not in another, which is uncomfortable for classification schemes and accurate.

Privacy safeguarding requirements

The framework's central organizing concept, and the one with no counterpart elsewhere. It is the consolidated obligation set for a processing activity, derived from four sources at once: law and regulation, contracts, the organization's own policies, and the privacy preferences of PII principals. Managing those four separately produces gaps at the joins, and this concept exists to close them. If you take one idea from this framework into a vocabulary that lacks it, take this one.

Privacy risk

Assessed by consequence *to the PII principal*, not to the organization. This is the distinction most often lost in implementation, because organizational risk processes naturally measure organizational impact — and privacy harm frequently falls entirely on someone else. A register counting only organizational impact has not assessed privacy risk at all.

On the “where this goes wrong” sections

Every other guide in this series ends each entry with suggested language for an audit finding. There are no findings here, because there is nothing to find against. That section has been replaced with the specific misreading each term actually produces.

These are not hypotheticals. Each one describes a mistake that appears in real privacy documentation: pseudonymised data described as anonymised, the website notice called a policy, security controls presented as the privacy control set, a conformity claim made against a framework that has nothing to conform to. If you are reviewing someone else's privacy documentation, these sections are a serviceable checklist.

Contents

Before You Use This Document	ii
1 The Eleven Privacy Principles	1
P1 Consent and choice Consent and choice	2
P2 Purpose legitimacy Purpose legitimacy and specification	3
P3 Collection limitation Collection limitation	4
P4 Data minimization Data minimization	5
P5 Use retention disclosure Use, retention and disclosure limitation	6
P6 Accuracy and quality Accuracy and quality	7
P7 Openness and notice Openness, transparency and notice	8
P8 Individual participation Individual participation and access	9
P9 Accountability Accountability	10
P10 Information security Information security	11
P11 Privacy compliance Privacy compliance	12
2 Actors and Their Roles	13
PII principal PII principal	14
PII controller PII controller	15
PII processor PII processor	16
Third party Third party	17
Role interaction How the roles combine and shift	18
3 Terminology	19
PII Personally identifiable information	20
Sensitive PII Sensitive PII	21
Identifiability Identifiability, anonymization, and pseudonymization	22
Consent and opt Consent, opt-in, and opt-out	23
Secondary use Secondary use	24
Privacy breach Privacy breach	25
Metadata Metadata as PII	26
4 Framework Components	27
Safeguarding requirements Privacy safeguarding requirements	28
Privacy risk assessment Privacy risk and privacy risk assessment	29
Privacy policy Privacy policy	30
Privacy controls Privacy controls	31
Relationship to other standards Where 29100 sits among the privacy standards	32
Free availability Availability of the standard itself	33
Glossary	34
Index of Terms and Concepts	36

CHAPTER 1

The Eleven Privacy Principles

The eleven privacy principles. This is the framework's core contribution alongside its vocabulary, and the set is wider than the regulatory principle sets most practitioners carry: eleven here against six plus accountability in the GDPR.

The extra principles are not additions layered on top. They are the same territory partitioned differently. Collection limitation is a principle here and is folded into minimisation there. Privacy compliance is a principle here and is folded into accountability there. Purpose specification and the constraint on further processing sit in one GDPR principle and in two separate principles here.

That makes one-to-one mapping unsafe in both directions, and it is why seven of these eleven entries are marked as diverging. Read the mapping section of each rather than assuming the name tells you what it covers.

Quick reference: the eleven principles

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
P1 Consent and choice cyb	Consent and choice	Opt-in and opt-out, mechanisms sitting inside choice
P2 Purpose legitimacy	Purpose legitimacy and specification	P5, which holds the downstream constraints GDPR keeps inside purpose limitation
P3 Collection limitation cyb	Collection limitation	P4, the adjacent principle addressing quantity and extent
P4 Data minimization cyb	Data minimization	P3, addressing whether PII enters at all
P5 Use retention disclosure cyb	Use, retention and disclosure limitation	P2, supplying the purpose test all three constraints apply
P6 Accuracy and quality cyb	Accuracy and quality	P8, through which a PII principal may challenge accuracy
P7 Openness and notice	Openness, transparency and notice	Privacy policy, the organization's own governing statement
P8 Individual participation cyb	Individual participation and access	PII principal, the participating party
P9 Accountability	Accountability	P11, the separate principle addressing verification
P10 Information security	Information security	Privacy controls, the wider category of which security controls are one part
P11 Privacy compliance cyb	Privacy compliance	P9, the adjacent principle covering responsibility and demonstrability

P1 Consent and choice Consent and choice

WHAT THE TERM MEANS

A single principle covering two things: presenting the individual with genuine options about processing, and obtaining consent where consent is the basis for it. Choice is the broader element. It concerns whether a real alternative existed, including the alternative of not participating, rather than only whether a consent event was captured.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Bundling them is deliberate. Consent obtained where no alternative existed is formally present and substantively empty, and naming choice alongside consent gives the framework language for that gap. Because 29100 is written to be jurisdiction-neutral, it describes the concept rather than the legal test any particular regime applies.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR splits this differently: consent is one of six lawful bases under Article 6, with validity conditions in Article 7. There is no GDPR principle called choice.
2. When a GDPR-trained reader says consent they mean the Article 6 basis. In 29100 consent is one element inside a wider principle.
3. ISO/IEC 27701 handles consent through controller-role controls rather than as a named principle.

RELATED TERMS AND WHERE THEY SIT

- Opt-in and opt-out, mechanisms sitting inside choice
- Privacy preferences, the recorded expression of choices made
- PII principal, the party exercising the choice

USING IT PRECISELY

Say which element you mean. Citing the principle without qualification leaves a reader unsure whether you are discussing a captured consent or the presence of a real alternative, and those are different findings with different remedies.

WHERE THIS GOES WRONG

The frequent misreading is treating this as equivalent to the GDPR consent basis, and concluding that a system with recorded consents satisfies it. Choice asks a separate question, and a bundled or unavoidable consent satisfies the mechanism while failing the principle.

P2 Purpose legitimacy Purpose legitimacy and specification

WHAT THE TERM MEANS

Purposes for processing must be both legitimate and specified. Legitimacy concerns whether the purpose is one the organization may properly pursue at all. Specification concerns whether it has been articulated precisely enough to constrain anything. Specification is expected at or before collection.

WHY THE FRAMEWORK DEFINES IT THIS WAY

The two elements fail independently. An organization can pursue an entirely proper purpose while describing it so broadly that it permits almost anything, and it can specify a purpose with great precision when that purpose is one it should not pursue. Naming both stops either failure hiding behind the other.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR distributes these across two places: lawfulness at Article 6, and the purpose limitation principle at Article 5(1)(b) carrying the specified, explicit and legitimate wording.
2. The GDPR principle also carries the constraint on further processing. 29100 puts that in a separate principle, so the two do not map cleanly in either direction.
3. ISO/IEC 27701 addresses purpose identification through controller-role controls.

RELATED TERMS AND WHERE THEY SIT

- P5, which holds the downstream constraints GDPR keeps inside purpose limitation
- Secondary use, processing for a purpose other than the specified one
- Privacy safeguarding requirements, derived partly from specified purposes

USING IT PRECISELY

Do not reach for this principle on downstream questions. Limits on subsequent use, retention, and disclosure live in P5, so citing P2 for a secondary-use issue points the reader at the wrong clause.

WHERE THIS GOES WRONG

The frequent misreading is mapping this straight onto GDPR purpose limitation. That GDPR principle covers specification and the incompatibility constraint together; 29100 splits them across P2 and P5. A one-to-one mapping loses half the meaning each way.

P3 Collection limitation Collection limitation

WHAT THE TERM MEANS

Collection of PII is limited to what is lawful and strictly necessary for the specified purposes. This operates at the moment of collection and asks whether the PII should be obtained at all, as distinct from how much is obtained or what happens to it afterwards.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Collection is the only point at which PII can be kept out of the organization entirely. Once collected, every later control is mitigation. Giving collection its own principle keeps that distinction visible rather than collapsing it into a general sufficiency test.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR has no standalone collection limitation principle. The equivalent constraint sits inside data minimisation at Article 5(1)(c).
2. This is one of the clearest structural divergences: 29100 has eleven principles where GDPR has six plus accountability, and collection limitation is one of the extras.
3. ISO/IEC 27701 handles collection through controls rather than as a named principle.

RELATED TERMS AND WHERE THEY SIT

- P4, the adjacent principle addressing quantity and extent
- P2, which supplies the necessity test collection is measured against

USING IT PRECISELY

Use P3 for whether PII should be obtained and P4 for how much. The distinction is finer than most regulatory vocabularies draw, which is exactly what makes it useful when you need to be precise about where a failure occurred.

WHERE THIS GOES WRONG

The frequent misreading is assuming a GDPR-trained reader will recognise the term. Collection limitation has no separate GDPR counterpart, so using it in a mixed-vocabulary document without explanation sends readers hunting for a principle that does not exist in the regime they know.

P4 Data minimization Data minimization

WHAT THE TERM MEANS

Minimising both the PII processed and the extent of processing itself. The framework's formulation reaches beyond fields collected to include limiting who has access, limiting observability, and limiting the degree to which PII is linked or made identifiable where the purpose does not require it.

WHY THE FRAMEWORK DEFINES IT THIS WAY

A sufficiency test on fields misses design choices that reduce exposure without reducing volume. Processing in aggregate, reducing linkage between datasets, and narrowing access all lower privacy risk while leaving record counts untouched, and this formulation captures them.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR Article 5(1)(c) uses adequate, relevant and limited to what is necessary, which is narrower and focused on the data itself.
2. The 29100 formulation reaches architecture and access questions that the GDPR wording addresses less directly.
3. ISO/IEC 27701 addresses minimisation through controls in both roles.

RELATED TERMS AND WHERE THEY SIT

- P3, addressing whether PII enters at all
- De-identification and pseudonymization, techniques reducing identifiability
- Privacy controls, the measures through which minimisation is implemented

USING IT PRECISELY

This is the accurate reference for a design choice that reduces exposure without reducing the record count. Reducing linkage, narrowing access, and processing in aggregate all sit here.

WHERE THIS GOES WRONG

The frequent misreading is applying this only to fields collected, as GDPR minimisation largely is. A dataset that is minimal in fields but unnecessarily linked and broadly accessible fails P4 while passing a narrow field test.

P5 Use retention disclosure Use, retention and disclosure limitation**WHAT THE TERM MEANS**

Constrains what happens to PII after collection. Use is limited to the specified purposes, retention to the period those purposes and applicable law require, and disclosure to what the purposes or law permit. The three share a principle because they share a test: the specified purpose.

WHY THE FRAMEWORK DEFINES IT THIS WAY

They are the same constraint applied at three moments in the lifecycle. An organization that uses PII beyond its purpose, keeps it past its need, or discloses it without basis has committed the same category of failure at different points, and the framework treats them together rather than separately.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR distributes these across purpose limitation at Article 5(1)(b) for use, storage limitation at Article 5(1)(e) for retention, and lawfulness requirements for disclosure.
2. This is the mirror image of the P2 divergence: GDPR splits what 29100 groups here, and groups what 29100 splits there.
3. ISO/IEC 27701 addresses retention and disposal through dedicated controls.

RELATED TERMS AND WHERE THEY SIT

- P2, supplying the purpose test all three constraints apply
- Secondary use, the term for processing beyond the specified purpose
- Third party, the party to whom disclosure may occur

USING IT PRECISELY

Cite P5 for retention questions rather than P2. Practitioners trained on GDPR reach for storage limitation, which does not exist as a separate principle in this vocabulary.

WHERE THIS GOES WRONG

The frequent misreading is looking for a storage limitation principle, not finding one, and concluding 29100 does not address retention. It does, inside P5, which is easy to miss because the name leads with use.

P6 Accuracy and quality Accuracy and quality

WHAT THE TERM MEANS

PII must be accurate, complete, up to date, adequate, and relevant for the purposes of processing. Quality is broader than accuracy: PII can be factually correct while being incomplete or stale in ways that make it unfit for the decision it informs.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Accuracy without quality produces confident wrong outcomes. A record correct as far as it goes but materially incomplete supports a decision as poorly as one containing an error, and naming quality separately makes that failure describable.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR Article 5(1)(d) covers accuracy and being kept up to date, with a rectification and erasure duty attached. Completeness and adequacy are less explicit there.
2. The vocabularies align more closely here than for most principles, but the quality element has no clean GDPR counterpart.
3. ISO/IEC 27701 addresses accuracy through controls including those supporting correction.

RELATED TERMS AND WHERE THEY SIT

- P8, through which a PII principal may challenge accuracy
- Privacy safeguarding requirements, setting the accuracy standard appropriate to the purpose

USING IT PRECISELY

Use quality when the issue is fitness for purpose rather than factual correctness. That distinction exists in this vocabulary and in few regulatory ones, which makes it worth reaching for deliberately.

WHERE THIS GOES WRONG

The frequent misreading is treating this as identical to GDPR accuracy and dropping the quality element. A dataset with no factual errors still fails P6 if it is materially incomplete for the decisions it drives.

P7 Openness and notice Openness, transparency and notice

WHAT THE TERM MEANS

Providing PII principals with clear and accessible information about the organization's policies, procedures, and practices for PII. Three distinct elements: general openness about how the organization operates, transparency about specific processing, and notice delivered at useful moments such as at or before collection.

WHY THE FRAMEWORK DEFINES IT THIS WAY

The three are not the same obligation. An organization can be open in general and opaque about a particular processing activity, or transparent in its documentation while never delivering notice at a point where it would inform a decision.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR names transparency at Article 5(1)(a) alongside lawfulness and fairness, with detailed information duties at Articles 12 to 14.
2. GDPR does not use openness as a term of art; the nearest equivalent is the accessibility requirement at Article 12.
3. ISO/IEC 27701 addresses notice through controller-role controls.

RELATED TERMS AND WHERE THEY SIT

- Privacy policy, the organization's own governing statement
- Privacy notice, what actually reaches the PII principal
- PII principal, the recipient of notice

USING IT PRECISELY

Keep policy and notice distinct in writing. In this vocabulary a privacy policy is internal and a notice is external, and conflating them produces documents that serve neither function.

WHERE THIS GOES WRONG

The frequent misreading is using privacy policy to mean the public-facing document. Here that document is a notice. Mixing the two makes cross-standard documents ambiguous about which artefact is being referenced.

P8 Individual participation Individual participation and access

WHAT THE TERM MEANS

The ability of PII principals to access and review their PII, challenge its accuracy and completeness, and have it amended, corrected, or removed where appropriate. Participation is the broader framing: the individual is a party with standing in the processing, not merely its subject.

WHY THE FRAMEWORK DEFINES IT THIS WAY

The framework leads with participation rather than a rights catalogue because it is jurisdiction-neutral. Specific rights vary considerably between regimes, and naming the underlying concept lets the framework describe what they have in common without adopting any one regime's list.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR enumerates specific rights across Articles 15 to 22: access, rectification, erasure, restriction, portability, objection, and rights around automated decisions.
2. 29100 has no rights catalogue, so mapping a specific GDPR right onto P8 is one-to-many in the wrong direction.
3. ISO/IEC 27701 provides controls supporting rights fulfilment in the controller role.

RELATED TERMS AND WHERE THEY SIT

- PII principal, the participating party
- P6, the standard against which a challenge is measured
- Privacy preferences, participation short of a formal request

USING IT PRECISELY

Do not treat this as a synonym for data subject rights. It names the concept those rights implement. A document equating them implies 29100 confers rights, which it does not: it is a framework, not a source of obligations.

WHERE THIS GOES WRONG

The frequent misreading is citing P8 as though it established entitlements. Enforceable rights come from law. The framework describes the concept regimes implement through them.

P9 Accountability Accountability

WHAT THE TERM MEANS

Assigning responsibility for adherence to privacy principles and requirements to specific parties, and being able to demonstrate that adherence. Covers documenting policies, assigning responsibility to named roles, training, and showing that measures actually operate.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Accountability is what makes the other principles assessable. Without an accountable party and a demonstrability requirement, the rest describe a desirable state with no mechanism for establishing whether it obtains. That structural role is why it appears in nearly every privacy framework.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR Article 5(2) states accountability in closely comparable terms: responsibility plus the ability to demonstrate compliance.
2. This is among the closest alignments between the two vocabularies.
3. ISO/IEC 27701 implements accountability through management system requirements as well as controls.

RELATED TERMS AND WHERE THEY SIT

- P11, the separate principle addressing verification
- PII controller, the party to whom accountability principally attaches
- Privacy policy, one artefact through which it is discharged

USING IT PRECISELY

Distinguish P9 from P11. This framework separates them: accountability is assigned responsibility plus demonstrability, while privacy compliance is verification against requirements.

WHERE THIS GOES WRONG

The frequent misreading is assuming P9 absorbs verification, as GDPR accountability largely does. Here verification has its own principle, so citing accountability for an audit question points at the wrong one.

P10 Information security Information security

WHAT THE TERM MEANS

Protecting PII with appropriate controls at operational, functional, and strategic levels, to preserve integrity, confidentiality, and availability, and to guard against unauthorised access, destruction, use, modification, disclosure, and loss.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Security appears as a privacy principle because privacy cannot hold without it: PII accessible or alterable by unauthorised parties is not protected whatever else is in place. The framework makes it one principle among eleven rather than the foundation, which reflects that security is necessary for privacy and nowhere near sufficient.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR Article 5(1)(f) uses integrity and confidentiality, with detailed requirements at Article 32.
2. The GDPR principle wording omits availability, though Article 32 includes it. 29100 names all three at principle level.
3. ISO/IEC 27701 draws its security controls from the ISO/IEC 27001 Annex A set.

RELATED TERMS AND WHERE THEY SIT

- Privacy controls, the wider category of which security controls are one part
- Privacy breach, the event this principle exists to prevent
- Privacy risk, to which security risk contributes without exhausting

USING IT PRECISELY

Keep security controls and privacy controls distinct. Security controls protect PII from unauthorised access; privacy controls include those but also address purpose, minimisation, and individual participation, which no security measure touches.

WHERE THIS GOES WRONG

The frequent misreading is treating P10 as the whole of privacy protection. An organization with strong security and no purpose limitation, no minimisation, and no individual participation satisfies one principle of eleven while failing the framework.

P11 Privacy compliance Privacy compliance

WHAT THE TERM MEANS

Verifying that processing meets applicable privacy safeguarding requirements, through periodic audits using internal or independent auditors, and retaining the evidence verification produces. This is the assurance principle: whether adherence has been checked, not whether it exists.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Verification and accountability answer different questions. Accountability establishes who is responsible and whether they can demonstrate adherence; privacy compliance establishes whether anyone has independently checked. An organization can be fully accountable and never verified.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR has no separate compliance-verification principle. Verification is implicit in accountability at Article 5(2), with audit obligations appearing in specific contexts such as processor arrangements.
2. This is 29100's other extra principle relative to GDPR, alongside P3.
3. ISO/IEC 27701 implements verification through management system requirements for internal audit and management review.

RELATED TERMS AND WHERE THEY SIT

- P9, the adjacent principle covering responsibility and demonstrability
- Privacy safeguarding requirements, the criteria verification tests against
- Privacy risk assessment, related but distinct

USING IT PRECISELY

Use P11 for verification questions and P9 for responsibility questions. The separation is one of the more useful distinctions this vocabulary offers, because it lets you describe an organization that owns its obligations but has never tested whether it meets them.

WHERE THIS GOES WRONG

The frequent misreading is omitting P11 when mapping to GDPR, because there is nothing to map it onto. It then vanishes from cross-referenced documents, taking the verification dimension with it.

CHAPTER 2

Actors and Their Roles

Five entries on the roles 29100 defines for processing personally identifiable information, and how they combine.

Two of these carry across from regulatory vocabulary safely: PII controller and PII processor align closely with their regulatory counterparts. Two do not. PII principal is an international consensus term chosen to work across regimes that do not share the European legal tradition, and treating it as a synonym for data subject imports assumptions that may not hold. Third party is defined more narrowly than casual usage suggests, and sits alongside the broader privacy stakeholder concept.

The entry worth acting on is the last. Role is determined per processing activity, not per organization, and this is the point most often collapsed. An organization that describes itself as a processor is describing its predominant role, not a property of everything it does. The subset where the role differs is usually the interesting one, because that is where obligations exist that nobody has identified.

Quick reference: Actors and Roles

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
PII principal^{cyb}	PII principal	P8, the principle describing what a principal may do
PII controller	PII controller	PII processor, the party acting on the controller's behalf
PII processor	PII processor	PII controller, the party issuing instructions
Third party^{cyb}	Third party	P5, constraining disclosure to third parties
Role interaction^{cyb}	How the roles combine and shift	PII controller and PII processor, the roles that shift

PII principal PII principal**WHAT THE TERM MEANS**

The natural person to whom the personally identifiable information relates. The framework uses principal rather than subject, and the choice is meaningful: a principal is a party with standing, which fits the participation framing of P8 better than a term implying passivity.

WHY THE FRAMEWORK DEFINES IT THIS WAY

29100 is written to be jurisdiction-neutral, and data subject is a term carrying specific European statutory meaning. Using a neutral term lets the framework describe the role without importing one regime's definition of who qualifies or what they are owed.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR says data subject. The two refer to the same person in almost all practical cases.
2. US state privacy laws variously use consumer, resident, or individual, none of which map cleanly onto either term.
3. ISO/IEC 27701 uses PII principal, following 29100 rather than GDPR.

RELATED TERMS AND WHERE THEY SIT

- P8, the principle describing what a principal may do
- Privacy preferences, the recorded expression of a principal's choices
- PII, the information the relationship is defined by

USING IT PRECISELY

Pick one term per document and define it once. Mixing PII principal and data subject in the same text implies a distinction that does not exist, and readers will spend effort looking for one.

WHERE THIS GOES WRONG

The frequent misreading is assuming the terms are interchangeable across contexts as well as in meaning. They denote the same person, but data subject carries European statutory baggage that PII principal deliberately avoids, which matters when the processing is governed by another regime.

PII controller PII controller**WHAT THE TERM MEANS**

The party that determines the purposes and means of processing PII, other than a natural person using PII for personal purposes. Determination is what defines the role: the controller decides why the processing happens and broadly how.

WHY THE FRAMEWORK DEFINES IT THIS WAY

The framework anchors the role in decision-making rather than in possession or contract, because possession is a poor guide. A party may hold large volumes of PII while determining nothing about it, and a party determining purposes may hold none of it directly.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR controller at Article 4(7) is defined in closely comparable terms. This is one of the safest terms to carry across.
2. The prefix is the only real difference: 29100 says PII controller, GDPR says controller.
3. ISO/IEC 27701 uses PII controller and organizes a whole set of controls around the role.

RELATED TERMS AND WHERE THEY SIT

- PII processor, the party acting on the controller's behalf
- P9, the principle attaching accountability principally to this role
- Role interaction, covering how the roles combine and shift

USING IT PRECISELY

Keep the PII prefix when writing in this vocabulary, and drop it when writing in GDPR vocabulary. The hybrid form data controller belongs to neither and signals imprecision.

WHERE THIS GOES WRONG

The frequent misreading is treating the role as fixed by contract. Determination is factual: a party contracted as a processor that decides purposes is a controller in substance, under both this framework and GDPR.

PII processor PII processor**WHAT THE TERM MEANS**

The party that processes PII on behalf of and in accordance with the instructions of a PII controller. The defining feature is acting on instruction: the processor does not determine why the processing occurs.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Defining the role by instruction rather than by activity keeps it distinguishable from a controller performing the same technical operations. Two organizations may run identical processing while occupying different roles, and only the instruction relationship separates them.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR processor at Article 4(8) is defined comparably. Another safe term to carry across.
2. Both vocabularies agree that exceeding instructions can make a processor a controller for that processing.
3. ISO/IEC 27701 organizes a separate control set around the processor role.

RELATED TERMS AND WHERE THEY SIT

- PII controller, the party issuing instructions
- Third party, distinct from a processor in both vocabularies
- Role interaction, covering dual-role organizations

USING IT PRECISELY

State which processing you mean when describing an organization's role. Most substantial organizations are controllers for some processing and processors for other processing, and a document assigning one role organization-wide will be wrong somewhere.

WHERE THIS GOES WRONG

The frequent misreading is assigning the role to an organization rather than to a processing activity. Roles attach to processing, not to companies, and the same entity routinely occupies both.

Third party Third party

WHAT THE TERM MEANS

A party other than the PII principal, the PII controller, and the PII processor. The definition is residual: it is everyone outside the three named roles for a given processing activity.

WHY THE FRAMEWORK DEFINES IT THIS WAY

A residual definition is the only reliable way to close the set. Attempting to enumerate the kinds of party that might receive PII would leave gaps, whereas defining by exclusion guarantees that any recipient falls somewhere.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR Article 4(10) defines third party residually too, but excludes the data subject, controller, processor, and persons authorised to process under their direct authority.
2. GDPR also distinguishes recipient at Article 4(9), which includes third parties but is broader. 29100 has no separate recipient term.
3. The absence of a recipient counterpart is the divergence that causes trouble in disclosure discussions.

RELATED TERMS AND WHERE THEY SIT

- P5, constraining disclosure to third parties
- PII processor, which is not a third party in either vocabulary
- Secondary use, often the reason disclosure occurs

USING IT PRECISELY

When writing about disclosure in a mixed-vocabulary document, say who the party is rather than relying on the label. Third party and recipient partition the space differently in the two vocabularies, so the label alone will not carry your meaning.

WHERE THIS GOES WRONG

The frequent misreading is assuming third party means the same in both vocabularies and can be used in disclosure mapping. GDPR splits the space with an additional term; 29100 does not, so a mapping built on the label alone will misclassify recipients.

Role interaction How the roles combine and shift

WHAT THE TERM MEANS

The framework treats roles as attaching to processing rather than to organizations, so a single party may occupy different roles for different processing, and roles may change as processing changes. A processor that begins determining purposes becomes a controller for that processing.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Anchoring roles to processing rather than to entities is what makes the model work for real organizations, which almost never occupy a single role cleanly. It also makes role determination an ongoing exercise rather than a one-time classification.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR takes the same position: roles follow the factual determination of purposes and means for the processing in question.
2. GDPR adds joint controllers at Article 26 for parties jointly determining purposes and means. 29100 does not name a joint role.
3. ISO/IEC 27701 accommodates dual-role organizations by providing separate control sets that can both apply.

RELATED TERMS AND WHERE THEY SIT

- PII controller and PII processor, the roles that shift
- Third party, which a party may also become
- P9, whose accountability follows the role

USING IT PRECISELY

Record roles against processing activities rather than against organizations, and revisit them when processing changes. A role determination made once at onboarding will drift.

WHERE THIS GOES WRONG

The frequent misreading is looking for joint controllership in this vocabulary and concluding it is unaddressed. 29100 has no joint role term; where GDPR would describe joint controllers, this framework describes each party's determination for the processing concerned.

Terminology

Seven entries on the vocabulary 29100 standardizes. Orange throughout, because this is where a reader fluent in regulatory language will silently mistranslate.

Three definitions repay close reading. Sensitive PII is contextual here rather than enumerated, which captures data that causes serious harm without appearing on any regulatory list – location history, financial distress indicators, and similar. Privacy breach is defined as processing in violation of safeguarding requirements, which is far wider than a security-shaped breach concept and covers processing beyond purpose or past retention with no security failure at all. And the anonymization boundary is stated unusually clearly: anonymized data leaves scope, pseudonymous data does not, and the test is irreversibility.

The metadata entry has no direct counterpart in most regulatory vocabulary and is worth the attention. Logs, telemetry, access records, and communication patterns are frequently identifying and revealing, they are retained longer than the content they describe, and an inventory built from application data models will not contain them.

Quick reference: Terminology

Navigation: every reference and title below links to its full entry. Links shown in orange with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are blue.

Ref	Title	Primary evidence
PII^{cyb}	Personally identifiable information	Sensitive PII, the subset attracting heightened treatment
Sensitive PII^{cyb}	Sensitive PII	PII, the broader category
Identifiability^{cyb}	Identifiability, anonymization, and pseudonymization	PII, which pseudonymized data remains and anonymized data is not
Consent and opt^{cyb}	Consent, opt-in, and opt-out	P1, the principle covering consent and choice together
Secondary use^{cyb}	Secondary use	P2, which specifies the original purpose
Privacy breach^{cyb}	Privacy breach	P10, the principle addressing security-type breaches
Metadata^{cyb}	Metadata as PII	PII, which metadata may constitute

PII Personally identifiable information

WHAT THE TERM MEANS

Any information that can be used to identify the natural person to whom it relates, or that is or might be directly or indirectly linked to that person. The test is linkability, and it extends to information that might be linked, not only information that is.

WHY THE FRAMEWORK DEFINES IT THIS WAY

The might be linked formulation makes the boundary relative rather than absolute. Whether information is PII depends on what else exists and who holds it, so the same dataset can be PII in one context and not in another. That is uncomfortable for classification schemes but accurate.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR personal data at Article 4(1) uses relating to an identified or identifiable natural person, with identifiability assessed against means reasonably likely to be used.
2. The concepts are close. The main difference is emphasis: 29100 foregrounds linkability, GDPR foregrounds identifiability.
3. ISO/IEC 27701 uses PII throughout, following 29100.

RELATED TERMS AND WHERE THEY SIT

- Sensitive PII, the subset attracting heightened treatment
- Identifiability, the underlying property
- Anonymization and pseudonymization, which act on it

USING IT PRECISELY

State the context when classifying. Because linkability depends on what other information exists, a classification decision without its context is not reproducible and will not survive scrutiny.

WHERE THIS GOES WRONG

The frequent misreading is treating PII status as a fixed property of a dataset. It is relative to available information and to who holds it, so a dataset correctly classified as non-PII in one environment may be PII in another.

Sensitive PII Sensitive PII

WHAT THE TERM MEANS

PII whose nature, context, or processing carries heightened potential for harm to the PII principal, warranting stronger safeguards. The framework treats sensitivity as arising from circumstance as well as from category.

WHY THE FRAMEWORK DEFINES IT THIS WAY

A purely categorical definition would miss information that is unremarkable in one setting and dangerous in another. Location data, for example, is not inherently sensitive but becomes so in contexts that reveal attendance at particular places, and the framework's formulation captures that.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR special categories at Article 9 is a closed list: racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data for identification, health, sex life, and sexual orientation.
2. This is a real structural divergence. GDPR enumerates; 29100 describes a property. Information can be sensitive under 29100 and outside Article 9 entirely.
3. ISO/IEC 27701 addresses sensitive PII through controls rather than a fixed list.

RELATED TERMS AND WHERE THEY SIT

- PII, the broader category
- Privacy risk, which sensitivity contributes to
- Privacy safeguarding requirements, which sensitivity elevates

USING IT PRECISELY

Do not use sensitive PII as shorthand for Article 9 special categories. If you mean the closed list, say special categories. If you mean information that is dangerous in context, sensitive PII is the correct term and the broader one.

WHERE THIS GOES WRONG

The frequent misreading is equating the two and concluding that anything outside Article 9 needs no heightened treatment. The framework's formulation is context-dependent and deliberately wider than any enumerated list.

Identifiability Identifiability, anonymization, and pseudonymization

WHAT THE TERM MEANS

Identifiability is the degree to which information can be associated with a specific person. Anonymization irreversibly removes that association so the result falls outside the framework's scope. Pseudonymization replaces identifiers with substitutes while retaining the means of re-association, so the result remains PII.

WHY THE FRAMEWORK DEFINES IT THIS WAY

The framework treats these as points on a spectrum rather than as binary states, which matters because most real techniques land somewhere between. Naming them separately prevents the common conflation where a pseudonymized dataset is described as anonymous.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR Recital 26 takes the same position: anonymous information falls outside the Regulation, pseudonymised data remains personal data.
2. GDPR defines pseudonymisation at Article 4(5) with the additional-information-held-separately condition.
3. This is one of the closer alignments, and one of the most frequently mishandled in practice regardless of vocabulary.

RELATED TERMS AND WHERE THEY SIT

- PII, which pseudonymized data remains and anonymized data is not
- P4, which these techniques help implement
- Privacy risk, reduced but not eliminated by pseudonymization

USING IT PRECISELY

Reserve anonymized for irreversible cases and test the claim before using it. Where re-association is possible through any means available to anyone, the correct term is pseudonymized and the data remains in scope.

WHERE THIS GOES WRONG

The frequent misreading is describing pseudonymized data as anonymized, which removes it from scope on paper while it remains PII in fact. This is the single most consequential terminology error in this vocabulary, because it silently disappplies every other protection.

Consent and opt Consent, opt-in, and opt-out

WHAT THE TERM MEANS

Consent is the PII principal's freely given, specific, informed agreement to processing. Opt-in and opt-out are mechanisms: opt-in requires an affirmative action before processing, opt-out permits processing until the principal acts to stop it.

WHY THE FRAMEWORK DEFINES IT THIS WAY

The framework separates the substance from the mechanism because the same mechanism can produce valid or invalid consent depending on how it is implemented. Naming them separately allows a document to describe a mechanism without asserting that the consent it produces is valid.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR requires an affirmative act for consent at Article 4(11), which effectively excludes opt-out as a consent mechanism.
2. Several US state regimes permit opt-out for some processing, so the mechanisms carry different legal weight by jurisdiction.
3. 29100 describes both neutrally because it is jurisdiction-neutral; that neutrality is not permission.

RELATED TERMS AND WHERE THEY SIT

- P1, the principle covering consent and choice together
- Privacy preferences, where opt states are recorded
- PII principal, the party whose consent is at issue

USING IT PRECISELY

Describe the mechanism and the applicable regime separately. Saying consent was obtained via opt-out is coherent in this vocabulary and describes something that is not valid consent under GDPR, so the regime has to be stated.

WHERE THIS GOES WRONG

The frequent misreading is inferring that because the framework describes opt-out neutrally, it is an acceptable consent mechanism. The framework describes; regimes decide. Under GDPR it is not.

Secondary use Secondary use

WHAT THE TERM MEANS

Processing of PII for a purpose other than the one for which it was originally collected. Whether secondary use is permissible depends on the applicable requirements and on the relationship between the new purpose and the original one.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Naming secondary use gives the framework a term for the most common way purpose limitation erodes. Each individual reuse of already-held data tends to look reasonable in isolation, and having a name for the category makes the aggregate drift describable.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR addresses this through the compatibility assessment at Article 6(4), with factors including the link between purposes, the context of collection, and the nature of the data.
2. 29100 names the concept; GDPR supplies a test. The framework does not provide an equivalent assessment procedure.
3. ISO/IEC 27701 addresses secondary use through controls on purpose determination.

RELATED TERMS AND WHERE THEY SIT

- P2, which specifies the original purpose
- P5, which constrains use to that purpose
- Privacy risk assessment, an appropriate vehicle for evaluating a proposed secondary use

USING IT PRECISELY

Use secondary use for the category and cite the applicable regime's test for permissibility. The framework identifies the question; it does not answer it.

WHERE THIS GOES WRONG

The frequent misreading is expecting the framework to supply a compatibility test. It names the concept without providing one, so a document relying on 29100 alone for a secondary-use decision has no basis to decide.

Privacy breach Privacy breach

WHAT THE TERM MEANS

A situation in which PII is processed in violation of privacy safeguarding requirements, or in which PII is compromised through unauthorised access, disclosure, alteration, or loss. The framework's formulation covers both security-type events and processing that breaches requirements without any security failure.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Restricting the term to security events would miss the larger category. PII processed for an unauthorised purpose, retained past its period, or disclosed without basis has been breached in the sense that matters to the individual, even though nothing was compromised in a security sense.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR personal data breach at Article 4(12) is narrower, requiring a breach of security leading to destruction, loss, alteration, unauthorised disclosure, or access.
2. Processing beyond purpose is not a GDPR personal data breach; it is an infringement. Under 29100 both fall within privacy breach.
3. This divergence matters directly for incident classification and for notification decisions.

RELATED TERMS AND WHERE THEY SIT

- P10, the principle addressing security-type breaches
- Privacy safeguarding requirements, the criteria a breach violates
- P5, whose violation is a privacy breach here but not a GDPR breach

USING IT PRECISELY

State which definition you are applying in incident documentation. Classifying an event as a privacy breach under this framework does not establish that it is notifiable under any particular regime.

WHERE THIS GOES WRONG

The frequent misreading is applying the framework's wider definition to a GDPR notification decision, or the narrower GDPR definition when describing the framework. The two do not partition incidents the same way, and the difference bears directly on what must be reported.

Metadata Metadata as PII

WHAT THE TERM MEANS

Information about processing, communications, or records that may itself be or become PII. The framework's linkability test applies to metadata as it does to content: information describing when, where, and between whom a communication occurred can identify individuals as readily as its content.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Metadata is systematically under-classified because it feels ancillary. Naming it explicitly within the PII discussion is a corrective, and it matters more as datasets grow, since metadata aggregates into identifiability more readily than content does.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR does not use metadata as a defined term, but personal data covers it wherever the identifiability test is met.
2. Sector rules such as those governing communications data address metadata specifically, with their own vocabulary.
3. The practical consequence is identical in both vocabularies; the framework is simply more explicit that it applies.

RELATED TERMS AND WHERE THEY SIT

- PII, which metadata may constitute
- Identifiability, the operative test
- P4, whose linkability dimension metadata bears on directly

USING IT PRECISELY

Apply the same classification test to metadata as to content, and record the result. Metadata excluded from a PII inventory without an explicit determination is usually an oversight rather than a decision.

WHERE THIS GOES WRONG

The frequent misreading is excluding metadata from PII inventories on the basis that it is not content. Log data, access records, and communication metadata routinely satisfy the linkability test and belong in scope.

Framework Components

Six entries on the structures 29100 supplies for organizing privacy work.

Privacy safeguarding requirements is the framework's most useful structural contribution and has no regulatory counterpart. It supplies one container for obligations arriving from four directions – law, contract, business policy, and the reasonable expectations of individuals – which is the actual situation most organizations are in. That fourth source is what a purely legal analysis omits, and it is frequently where reputational damage originates.

Privacy risk assessment carries the distinction that separates a genuine privacy programme from a security programme relabelled: risk here concerns the individual, not only the organization. The diagnostic is simple. If a privacy risk register contains no risk rated serious for individuals but negligible for the organization, it is being assessed from the wrong perspective.

Finally, two practical points. Nothing is certified against 29100 – it is a framework containing no requirements, so claims of 29100 compliance in customer materials are either loose language or misrepresentation. And unlike every other ISO standard in this series, it costs nothing. Obtain it and circulate it rather than working from summaries.

Quick reference: Framework Components

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Safeguarding requirements^{cyb}	Privacy safeguarding requirements	Privacy controls, selected to satisfy these requirements
Privacy risk assessment^{cyb}	Privacy risk and privacy risk assessment	Privacy safeguarding requirements, informed by the assessment
Privacy policy^{cyb}	Privacy policy	Privacy notice, the external counterpart
Privacy controls^{cyb}	Privacy controls	Privacy safeguarding requirements, which controls implement
Relationship to other standards^{cyb}	Where 29100 sits among the privacy standards	ISO/IEC 27701, the certifiable PIMS standard
Free availability^{cyb}	Availability of the standard itself	ISO/IEC 27701, which uses this vocabulary and is not free

Safeguarding requirements Privacy safeguarding requirements

WHAT THE TERM MEANS

The set of requirements an organization must satisfy for a given processing activity, derived from applicable law and regulation, contracts, the organization's own policies, and the privacy preferences of PII principals. The framework treats these four sources as contributing together.

WHY THE FRAMEWORK DEFINES IT THIS WAY

This is the framework's central organizing concept and it has no clean counterpart elsewhere. It exists because the obligations governing any real processing come from several directions at once, and managing them separately produces gaps at the joins. Consolidating them into one derived set is what allows controls to be selected coherently.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR has no equivalent term. Its obligations come from the Regulation itself, with contractual and policy obligations handled separately.
2. This is a concept the framework contributes rather than translates, which is one of the better reasons to use 29100 vocabulary at all.
3. ISO/IEC 27701 approaches the same problem through its management system requirements.

RELATED TERMS AND WHERE THEY SIT

- Privacy controls, selected to satisfy these requirements
- Privacy risk assessment, which informs their derivation
- P11, which verifies adherence to them

USING IT PRECISELY

Use this term when you need to describe the whole obligation set rather than one source of it. It is the most useful concept 29100 offers to a practitioner already fluent in regulatory vocabulary, precisely because that vocabulary lacks it.

WHERE THIS GOES WRONG

The frequent misreading is treating the term as a synonym for legal requirements. It is deliberately wider, and an organization deriving safeguarding requirements from law alone has omitted contractual, policy, and preference-based obligations it is equally bound by.

Privacy risk assessment Privacy risk and privacy risk assessment

WHAT THE TERM MEANS

Privacy risk is the effect of uncertainty on privacy, assessed in terms of likelihood and consequence for the PII principal. Privacy risk assessment is the process of identifying, analysing, and evaluating it, and it informs the derivation of safeguarding requirements and the selection of controls.

WHY THE FRAMEWORK DEFINES IT THIS WAY

The framework locates consequence with the individual rather than with the organization. That is the defining feature and the one most often lost in implementation, because organizational risk processes naturally measure organizational impact and privacy risk frequently falls on someone else entirely.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR requires a data protection impact assessment at Article 35 where processing is likely to result in high risk to rights and freedoms of natural persons.
2. The GDPR framing also centres the individual, so the concepts align well even though the terms differ.
3. ISO/IEC 29134 supplies a privacy impact assessment methodology; 29100 does not.

RELATED TERMS AND WHERE THEY SIT

- Privacy safeguarding requirements, informed by the assessment
- Privacy controls, selected on its output
- Sensitive PII, which raises assessed risk

USING IT PRECISELY

Distinguish privacy risk from information security risk explicitly in any document covering both. They are assessed from different perspectives and a combined register that does not separate them will default to the organizational view.

WHERE THIS GOES WRONG

The frequent misreading is assessing privacy risk as a subset of security risk, measured by organizational impact. Privacy risk includes harm to the individual, which may be severe where organizational impact is negligible, and a register counting only the latter has not assessed it.

Privacy policy Privacy policy

WHAT THE TERM MEANS

The organization's own statement of intentions, rules, and commitments regarding the processing of PII. In this vocabulary a policy is internal and governing: it directs the organization's behaviour rather than informing the PII principal.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Keeping policy internal and notice external is a deliberate separation. The two documents serve different audiences and different purposes, and a single artefact attempting both typically fails at each: too legalistic to inform an individual, too general to direct an organization.

MAPPING TO VOCABULARY YOU ALREADY USE

1. Common usage, including much GDPR practice, uses privacy policy to mean the public-facing document. In this vocabulary that is a notice.
2. GDPR itself does not define privacy policy; its Articles 13 and 14 govern information provided to data subjects, which is notice.
3. This is a terminology divergence from ordinary usage rather than from the Regulation's own text.

RELATED TERMS AND WHERE THEY SIT

- Privacy notice, the external counterpart
- P7, which covers both
- P9, discharged partly through policy

USING IT PRECISELY

Say privacy notice when you mean the public document. Reserve privacy policy for the internal governing statement. In mixed-audience documents, define both terms at first use, because ordinary usage conflicts with this vocabulary.

WHERE THIS GOES WRONG

The frequent misreading is the most common terminology error in this entire vocabulary: calling the website document a privacy policy. It is a notice. The confusion propagates into requirements documents and produces artefacts that serve neither audience.

Privacy controls Privacy controls

WHAT THE TERM MEANS

Measures that treat privacy risk by reducing likelihood or consequence, implemented to satisfy privacy safeguarding requirements. The category includes technical, administrative, and physical measures, and is broader than security controls.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Distinguishing privacy controls from security controls is necessary because the sets overlap without coinciding. Encryption is both. A purpose-limitation procedure or a rights-fulfilment process is a privacy control and not a security one, and a boundary firewall is the reverse.

MAPPING TO VOCABULARY YOU ALREADY USE

1. GDPR speaks of technical and organisational measures, which spans both categories without distinguishing them.
2. ISO/IEC 27701 draws its security controls from ISO/IEC 27001 Annex A and adds privacy-specific controls for the controller and processor roles, which mirrors this distinction.
3. ISO/IEC 29151 provides a privacy control set aligned with this framework.

RELATED TERMS AND WHERE THEY SIT

- Privacy safeguarding requirements, which controls implement
- P10, whose controls are a subset of these
- Privacy risk assessment, which drives selection

USING IT PRECISELY

Say privacy control when the measure addresses purpose, minimisation, participation, or transparency, and security control when it addresses confidentiality, integrity, or availability. Where a measure does both, say so rather than picking one.

WHERE THIS GOES WRONG

The frequent misreading is treating the security control set as the privacy control set. An organization with comprehensive security controls and no purpose, minimisation, or participation controls has implemented one part of the category.

Relationship to other standards Where 29100 sits among the privacy standards

WHAT THE TERM MEANS

29100 supplies the vocabulary and principles that several other standards build on. ISO/IEC 27701 specifies a privacy information management system and uses this terminology. ISO/IEC 29134 provides a privacy impact assessment methodology. ISO/IEC 29151 provides a privacy control set. The framework itself specifies nothing to conform to.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Understanding the family prevents a category error. 29100 is definitional infrastructure: it exists so that the standards above it can share a vocabulary rather than each defining its own. Reading it as a standard to implement misunderstands what it is for.

MAPPING TO VOCABULARY YOU ALREADY USE

1. Nothing is certified against 29100. Certification in this family runs against ISO/IEC 27701.
2. Where a document cites 29100 for an obligation, that citation is almost certainly wrong; the obligation will come from law or from one of the standards built on it.
3. The terminology in 27701, 29134, and 29151 derives from here, which is why those documents say PII principal rather than data subject.

RELATED TERMS AND WHERE THEY SIT

- ISO/IEC 27701, the certifiable PIMS standard
- ISO/IEC 29134, privacy impact assessment
- ISO/IEC 29151, privacy controls

USING IT PRECISELY

Cite 29100 for definitions and for the principle set. Cite the standard above it for anything that must be done. A requirements document whose obligations trace to 29100 has cited the wrong source.

WHERE THIS GOES WRONG

The frequent misreading is treating 29100 as a compliance standard and claiming conformity with it. There is nothing to conform to, and such a claim tells a reader only that the claimant has misunderstood the document.

Free availability Availability of the standard itself**WHAT THE TERM MEANS**

Unlike most of the ISO/IEC catalogue, ISO/IEC 29100 has been made available at no charge through the ISO and IEC freely available standards programmes. The 2024 edition is the second, a minor revision of the 2011 original incorporating Amendment 1:2018.

WHY THE FRAMEWORK DEFINES IT THIS WAY

Free availability is unusual and it is the practical reason this vocabulary is worth adopting. A terminology standard achieves nothing if the people who need to share the vocabulary cannot read it, and paywalling definitional infrastructure defeats its purpose.

MAPPING TO VOCABULARY YOU ALREADY USE

1. Most standards referenced in this guide series are paywalled, including ISO/IEC 27701, 17021-1, and 27706.
2. This means you can circulate the source document to colleagues, which is not true of the standards built on it.
3. Verify current availability before relying on it; programme contents change.

RELATED TERMS AND WHERE THEY SIT

- ISO/IEC 27701, which uses this vocabulary and is not free
- The 2011 first edition and Amendment 1:2018, which the 2024 edition consolidates

USING IT PRECISELY

Where a team needs shared vocabulary, circulate the standard itself rather than a summary. This is one of the few cases in privacy standards where that is possible, and a shared primary source beats any secondary description including this one.

WHERE THIS GOES WRONG

The frequent misreading is assuming the 2024 edition changed substantively because the year changed. It is a minor revision consolidating the 2011 text with Amendment 1:2018, so material written against the earlier edition largely remains sound.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Anonymization

Irreversible alteration of PII such that the individual can no longer be identified directly or indirectly. Anonymized data leaves the framework's scope entirely, which is why claims of anonymization warrant testing for reversibility.

Consent

Freely given, specific, and informed agreement to processing. A principle in its own right in this framework, unlike regulatory regimes that treat it as one lawful basis among several.

Identifiability

The condition allowing a natural person to be identified directly or indirectly. The operative test for whether information is PII, assessed against means reasonably likely to be used including by parties other than the holder.

Metadata

Data about processing, communications, or system use. Frequently identifying and revealing, commonly retained longer than the content it describes, and systematically absent from inventories built from application data models.

Opt-in

A process requiring the individual to act to express agreement before processing occurs. Expected for sensitive PII under the consent principle.

Opt-out

A process requiring the individual to act to prevent processing that would otherwise occur.

PII

Personally identifiable information: information that can be linked to a natural person directly or indirectly. Overlaps heavily with 'personal data' but is not an identical term, and the difference surfaces at the edges.

PII controller

The party determining purposes and means of processing. Delegating processing does not transfer accountability.

PII principal

The natural person the information relates to. The framework's neutral term, chosen to work across regimes rather than importing one tradition's legal meaning.

PII processor

The party processing on behalf of and per the instructions of a controller. Processing beyond instructions makes it a controller for that processing.

Privacy breach

Processing in violation of privacy safeguarding requirements. Materially wider than a security-shaped breach concept: covers processing beyond purpose or past retention with no security failure involved.

Privacy control

A measure treating privacy risk by reducing its likelihood or consequences, selected to meet safeguarding requirements.

Privacy preferences

The specific choices an individual has expressed about handling of their information. Operational data that must actually be honoured downstream, not merely recorded.

Privacy risk

The effect of uncertainty on privacy. Concerns the individual, not only the organization – the distinction separating privacy risk assessment from security risk assessment relabelled.

Privacy safeguarding requirements

The set of requirements an organization must meet when processing PII, drawn from law, contract, business policy, and the reasonable expectations of individuals. The framework's most useful structural contribution, with no regulatory counterpart.

Privacy stakeholder

Any party that can affect, be affected by, or perceive itself affected by a decision or activity related to PII processing. Broader than the enumerated roles, and deliberately so.

Privacy-enhancing technology

A technical measure protecting privacy by eliminating or reducing PII, or preventing unwanted processing, without losing functionality. The functionality condition is part of the definition.

Pseudonymous data

Data with identifiers substituted by aliases. Remains PII where re-identification is possible, and is not anonymized data.

Secondary use

Processing in conditions differing from the original collection purposes. Requires its own justification rather than resting on the original collection.

Sensitive PII

PII whose nature, context, or jurisdiction warrants heightened protection. Contextual rather than an enumerated list, which captures harmful data that appears on no regulatory schedule.

Third party

A privacy stakeholder other than the principal, controller, processor, and persons acting under the direct authority of the controller or processor.

Workpaper

The assessor's record of what was tested, how, what was found, and what was concluded.

Index of Terms and Concepts

- Accountability, 10
- Accuracy and quality, 7
- Anonymization, 34
- Availability of the standard itself, 33
- Collection limitation, 4
- Consent, 34
- Consent and choice, 2
- Consent, opt-in, and opt-out, 23
- Data minimization, 5
- How the roles combine and shift, 18
- Identifiability, 34
- Identifiability, anonymization, and pseudonymization, 22
- Individual participation and access, 9
- Information security, 11
- Metadata, 34
- Metadata as PII, 26
- Openness, transparency and notice, 8
- Opt-in, 34
- Opt-out, 34
- Personally identifiable information, 20
- PII, 34
- PII controller, 15, 34
- PII principal, 14, 34
- PII processor, 16, 34
- Privacy breach, 25, 35
- Privacy compliance, 12
- Privacy control, 35
- Privacy controls, 31
- Privacy policy, 30
- Privacy preferences, 35
- Privacy risk, 35
- Privacy risk and privacy risk assessment, 29
- Privacy safeguarding requirements, 28, 35
- Privacy stakeholder, 35
- Privacy-enhancing technology, 35
- Pseudonymous data, 35
- Purpose legitimacy and specification, 3
- Secondary use, 24, 35
- Sensitive PII, 21, 35
- Third party, 17, 35
- Use, retention and disclosure limitation, 6
- Where 29100 sits among the privacy standards, 32
- Workpaper, 35